



Build an edtech compliance matrix: 1EdTech TrustEd Apps, HECVAT, and EDUCAUSE 2026 standards in one audit scorecard

Computer

Higher-ed feature roadmap & gap analysis: turn 1EdTech and HECVAT compliance requirements into a prioritized product backlog

Computer

Show me the HECVAT mapping table

Draft the 1EdTech trusted apps evidence checklist

Turn this into an automated compliance dashboard API

The right automated compliance product for Semester is a **control-and-evidence platform**: one internal source of truth that maps product controls, policies, tests, artifacts, owners, risks, and remediation work to HECVAT, 1EdTech TrustEd Apps, EDUCAUSE priorities, and your own release gates.

It should never auto-certify Semester or claim compliance from a checkbox. It should show whether a control is implemented, tested, evidenced, expiring, partially met, or blocked—and produce audit-ready exports for customers.

1EdTech's TrustEd Apps materials cover data privacy, security practices, accessibility, and generative-AI data self-assessments; the security rubric organizes review around documentation/company information, data, systems management, and third-party assessment. ^[1685]_[1426]

HECVAT mapping table

HECVAT versions and customer-required sections vary, so map to the current questionnaire used by the target institution rather than relying solely on generic section names. HECVAT 4 is commonly organized around Organization, Product, Infrastructure, IT Accessibility, Privacy, AI Governance, and case-specific sections. ^[^1688]

HECVAT domain	Semester controls	Key platform features	Minimum evidence	Control owner	Typical priority
Organization	Governance charter, security/privacy policies, risk register, training, insurance, audit process	Operations Console risk register; policy/version service	Approved policies, RACI, risk-review minutes, training records	Security/Legal	P0/P1
Product	Secure SDLC, threat modeling, code review, vulnerability management, change control	CI/CD gates, feature flags, release-impact checker, audit log	PR/CI evidence, scan reports, threat models, release approvals	Engineering/Security	P0
Infrastructure	Cloud security, segmentation, encryption, secrets, backups, monitoring, DR	Tenant isolation, KMS/secret vault, backup service, integration gateway	Architecture diagrams, configuration evidence, restore tests, monitoring reports	Engineering/SRE	P0
Identity and access	SSO, MFA, role-based access, least privilege, access review, offboarding	Shared identity, RoleGrant, privileged-access workflow, session center	IdP configuration, RBAC matrix, quarterly access-review report, offboarding sample	Security/IT	P0
Privacy	Data inventory, purpose limitation, FERPA/DPA workflow, retention, deletion, subprocessors	Data-agency center, consent/share engine, retention service, subprocessor registry	Data map, DPA, privacy policy, deletion test, consent/audit log	Privacy/Legal	P0
IT accessibility	WCAG target, accessible procurement, issue management, ACR/VPAT, alternatives	Design system, accessibility preferences, release gate, accessible assessment engine	ACR/VPAT, manual/automated test evidence, remediation tracker	Accessibility/Product	P0/P1

HECVAT domain	Semester controls	Key platform features	Minimum evidence	Control owner	Typical priority
AI governance	AI inventory, provider assessment, data-use restrictions, evaluations, human oversight, incident response	AI control plane, policy engine, model inventory, evaluation service, kill switches	AI policy, provider terms, evaluation/red-team reports, change log	AI governance/Security	P0/P1
Logging and monitoring	Security logs, audit trail, alerting, retention, investigation	AuditEvent service, SIEM integration, alert rules, evidence vault	Log architecture, sample investigations, alert test, retention config	Security/SRE	P1
Incident response	Severity model, customer notification, tabletop testing, post-incident action	Incident console, status communications, runbook service	IR plan, tabletop report, corrective-action tracker	Security/Operations	P0
Business continuity	RTO/RPO, backups, restore, vendor outage, key-person risk	Backup/restore workflow, runbook library, failover/feature flags	BCP/DR plan, restore evidence, continuity exercise	SRE/Operations	P0/P1
Third-party risk	Vendor inventory, DPAs, security review, AI-provider review, exit plan	Vendor registry, contract/promise checker, subprocessor page	Due-diligence record, DPA, SOC/assessment review, offboarding plan	Privacy/Security	P0
Integration/API security	OAuth/OIDC, scoped tokens, key rotation, rate limits, tenant isolation, reconciliation	Integration gateway, LTI 1.3/OneRoster, webhook service, sync health	Data flow, scope list, penetration tests, LTI validation log	Integrations/Security	P0/P1
Data integrity	Grade/audit ledger, idempotency, approval, reconciliation, versioning	Gradebook ledger, consent ledger, content versioning	Calculation test suite, change log, reconciliation report	Engineering/Academic Ops	P0
Physical/endpoints	Device management, encryption, secure disposal, BYOD control	Workforce-device inventory and endpoint compliance integration	MDM reports, asset inventory, offboarding record	IT/Security	P1

HECVAT domain	Semester controls	Key platform features	Minimum evidence	Control owner	Typical priority
Case-specific controls	Payments, proctoring, health/basic-needs, minors, research, community safety	Payments boundary, referral service, moderation system, age/guardian policy	DPIA/risk assessment, workflow tests, partner agreements	Product/Legal	P0/P1

1EdTech TrustEd Apps evidence checklist

The checklist below is structured around the public TrustEd Apps program and rubric categories. The exact certification/self-assessment requirements and rubric version should be confirmed directly with 1EdTech before submission.

Documentation and company information

- [] Company legal identity, support contacts, privacy contact, security contact, accessibility contact, and incident contact are current.
- [] Public Privacy Policy and Terms of Service are current, plain-language, accurate, versioned, and consistent with actual system behavior.
- [] Public AI policy explains model use, data use, providers, training default, source/limitation labels, user reporting, and human-review boundaries.
- [] Public accessibility statement and current ACR/VPAT are available.
- [] Security overview, vulnerability-disclosure process, status page, subprocessor list, and data-processing documentation are available.
- [] Product/security/privacy/accessibility/AI documentation has an owner, issue date, next review date, and change history.
- [] Every sales, marketing, and procurement claim is linked to an evidence record.
- [] External assurance artifacts are accurately described:
SOC 2, penetration test, standards conformance, or other assessments—
with no unsupported certification claim.

Data privacy

- [] Data inventory identifies data collected, collection method, purpose, owner, classification, system/location, sharing, retention, and deletion path.
- [] Student and customer data are used only to provide/secure/improve authorized services under disclosed terms.
- [] No sale of student data or behavioral advertising based on education, support, accessibility, or sensitive data.

- [] Student/institution data ownership and control language is clear.
- [] Data sharing is purpose-bound, role-bound, logged, and disclosed.
- [] Subprocessors and third-party hosting are disclosed and reviewed.
- [] Customer/student export, correction, deletion, restriction, and share-revocation processes are technically implemented where applicable.
- [] Retention periods or retention rules are specific by data class.
- [] Legal-hold process suspends eligible deletion and resumes appropriately after release.
- [] Cookies, analytics, tracking, and advertising practices are disclosed and controlled.
- [] FERPA disclosure/consent and school-official workflows are documented, tenant-configurable, and auditable.
- [] Production customer/student data is not used to train general-purpose AI models by default.

Security practices

- [] Tenant separation is logically and technically enforced.
- [] Encryption in transit and at rest is implemented and documented.
- [] Identity lifecycle supports SSO, MFA for privileged roles, session management, access review, offboarding, and break-glass control.
- [] Secure SDLC includes code review, branch protection, dependency/secrets scanning, security testing, environment separation, deployment approval, and rollback.
- [] Vulnerability-management process has severity definitions, remediation SLAs, scanning evidence, exception process, and penetration-test plan.
- [] Logging covers authentication, authorization, privileged action, sensitive-data access, admin configuration, integration writes, grade changes, consent, and AI policy actions.
- [] Incident response includes detection, containment, investigation, notification, customer communication, post-incident review, and corrective actions.
- [] Backup, recovery, RTO/RPO, and business-continuity controls are tested.
- [] Support/operations access is least privilege, time-bound, reason-coded, logged, and reviewable.
- [] Sensitive test data policy prohibits ordinary production-data use in development, demo, and test environments.
- [] Secure deletion, media disposal, endpoint/device management, and workforce security training are evidenced.

Accessibility

- [] WCAG 2.2 AA target and scope are documented.
- [] Student, faculty, staff, admin, customer portal, and Operations Console workflows are included in accessibility testing.
- [] Keyboard-only, screen-reader, zoom/reflow, mobile, contrast, reduced motion, captions/transcripts, accessible math, tables/charts, and document workflows are
- [] Every core assessment interaction has an accessible equivalent.
- [] Accessibility preferences are available without diagnosis disclosure.
- [] AI-generated content workflows include alt-text/caption/heading/table/chart check and do not claim automatic accessibility conformance.
- [] Accessibility defects have severity, owner, target date, workaround, customer communication, and release-blocking criteria.
- [] ACR/VPAT is evidence-based and accurately discloses known limitations.
- [] Accessibility feedback route exists and is monitored.

Generative AI data and governance

- [] AI feature inventory identifies use case, model/provider/version, data categories, sources, users, tenant availability, risk tier, and owner.
- [] AI outputs show source, scope, status, policy state, and limitations where applicable.
- [] Course/institution policy controls govern allowed, restricted, and prohibited AI
- [] AI provider retention, training, location, subprocessor, deletion, security, and incident terms are reviewed before activation.
- [] Retrieval is tenant-scoped; no cross-tenant data access.
- [] AI safety testing covers grounding, hallucinations, bias, accessibility, prompt injection, data leakage, misuse, and tool actions.
- [] AI has no authority to make admissions, financial-aid, discipline, accommodation, health, legal, or other high-impact decisions.
- [] High-risk actions require human approval, audit logging, and a report/appeal route
- [] Model/provider changes trigger risk review and re-evaluation.
- [] AI logs are minimized, access-controlled, retained by policy, and included in deletion/export workflows as applicable.

1EdTech's security rubric specifically asks about external audits, tenant/data separation, transport encryption, and third-party hosting/sharing. It treats disclosure and purpose-limited hosting/sharing as stronger alignment than undisclosed secondary sharing. [^1426] The TrustEd Apps program states that members can pursue Data Privacy Certification and complete Accessibility, Generative AI Data, and Security Practices self-assessments. [^1685]

Automated compliance dashboard API

The dashboard should be an internal **control-plane service** first. Later, it can provide a restricted customer-facing Trust Evidence view.

Core resources

```
/frameworks
/frameworks/{framework_id}/controls
/controls
/controls/{control_id}
/controls/{control_id}/mappings
/evidence
/evidence/{evidence_id}
/assessments
/assessments/{assessment_id}
/findings
/findings/{finding_id}
/remediations
/remediations/{remediation_id}
/risks
/risks/{risk_id}
/exceptions
/exceptions/{exception_id}
/policies
/policies/{policy_id}
/systems
/systems/{system_id}
/vendors
/vendors/{vendor_id}
/releases
/releases/{release_id}/compliance
/dashboard/summary
/dashboard/frameworks/{framework_id}
/dashboard/tenant/{tenant_id}
/exports/hecvat
/exports/trusted-apps
/exports/customer-trust-evidence
```

Core schemas

Control

```
{
  "id": "CTRL-AI-004",
  "title": "AI provider data-use review",
  "domain": "AI governance",
  "description": "Each production AI provider is assessed before activation and annual",
  "risk_level": "high",
  "owner_role": "ai_governance_lead",
  "implementation_status": "implemented",
  "operating_effectiveness": "effective",
  "review_frequency": "annual_and_on_change",
  "next_review_at": "2027-01-15",
  "evidence_status": "current",
  "mappings": [
    {
      "framework": "HECVAT_4",
      "control_reference": "AI-GOV-[tenant-specific reference]"
    },
    {
      "framework": "1EDTECH_GENAI_RUBRIC",
      "control_reference": "AI-[rubric-version-specific reference]"
    }
  ]
}
```

Evidence

```
{
  "id": "EVD-AI-2026-018",
  "control_id": "CTRL-AI-004",
  "type": "vendor_assessment",
  "title": "Approved model provider review",
  "classification": "confidential",
  "storage_reference": "evidence-vault://ai/provider-review/2026-018",
  "hash": "sha256:...",
  "issued_at": "2026-09-15",
  "expires_at": "2027-09-15",
  "reviewed_by": "privacy_lead",
  "status": "approved",
  "coverage": {
    "systems": ["ai_gateway"],
    "vendors": ["provider_001"],
    "tenants": ["global"]
  }
}
```


Finding and remediation

```
{
  "finding": {
    "id": "FND-ACC-041",
    "control_id": "CTRL-ACC-007",
    "severity": "high",
    "status": "open",
    "summary": "Keyboard focus is lost after submission in the assessment review dia.",
    "source": "release_accessibility_test",
    "detected_at": "2026-09-28T15:00:00Z",
    "affected_systems": ["assessment_delivery"],
    "release_blocking": true
  },
  "remediation": {
    "id": "REM-ACC-041",
    "finding_id": "FND-ACC-041",
    "owner": "frontend_team",
    "target_date": "2026-10-05",
    "status": "in_progress",
    "validation_plan": "Keyboard-only and NVDA/VoiceOver regression test."
  }
}
```

Dashboard calculations

Framework coverage:

Mapped controls / required applicable controls.

Implementation score:

Controls implemented / applicable controls.

Evidence freshness:

Controls with unexpired approved evidence / controls requiring evidence.

Operating effectiveness:

Controls passing latest test / controls tested.

Risk exposure:

Open findings weighted by severity and affected-system criticality.

Release readiness:

Open release-blocking P0/P1 findings, expiring evidence,
unapproved high-risk exceptions, and untested changed controls.

Customer readiness:

Current HECVAT answer library + required evidence + current policy set +
customer-specific integration/data map.

Sample dashboard response

```
{
  "framework": "HECVAT_4",
  "generated_at": "2026-09-28T16:00:00Z",
  "coverage": {
    "applicable_controls": 218,
    "mapped_controls": 212,
    "coverage_percent": 97.2
  },
  "effectiveness": {
    "effective": 178,
    "partially_effective": 24,
    "ineffective": 3,
    "not_tested": 13
  },
  "evidence": {
    "current": 190,
    "expiring_within_30_days": 12,
    "expired": 4,
    "missing": 12
  },
  "findings": {
    "p0": 0,
    "p1": 3,
    "p2": 11,
    "p3": 26
  },
  "release_readiness": "blocked",
  "blockers": [
    "FND-ACC-041",
    "FND-IAM-009"
  ]
}
```

Automation sources

Identity provider:

MFA posture, role membership, privileged access, deprovisioning events.

Cloud/infrastructure:

Encryption, backups, KMS, logging, network configuration, asset inventory.

CI/CD:

Code review, branch protection, SAST, DAST, dependency scanning, secrets scanning, release approvals.

Application:

Tenant-isolation tests, audit-event coverage, consent/revocation tests, grade-ledger tests, API authorization tests.

AI gateway:

Model/provider inventory, policy checks, evaluation status, blocked requests, incident records, provider reviews.

Accessibility:

Automated test results, manual test records, open defects, release gate status.

Ticketing/project system:

Findings, owners, target dates, remediation status, exception approvals.

Document/evidence vault:

Policy versions, audit reports, DPAs, SOC/pentest material, signed approvals.

Guardrails

Never store sensitive audit artifacts directly in a broadly accessible dashboard data.
Store a reference, hash, classification, owner, expiry, and access policy;
retrieve the original only through an authorized evidence vault.

Do not auto-mark a control “effective” merely because a policy exists.

Require evidence of implementation and operating effectiveness.

Do not hardcode a generic HECVAT question number as universal truth.

Question IDs and applicability can differ by HECVAT version and customer use.

Separate:

Control implementation status

Evidence freshness

Test effectiveness

Risk acceptance

Customer-specific applicability

Marketing/public claim eligibility

Automated release gate

Every production release should submit a machine-readable compliance manifest:

```
{
  "release_id": "rel_2026_10_04_01",
  "systems_changed": ["assessment_delivery", "ai_gateway"],
  "data_classes_affected": ["student_submission", "ai_prompt"],
  "controls_requiring_retest": [
    "CTRL-ACC-007",
    "CTRL-AI-011",
    "CTRL-PRIV-006"
  ],
  "evidence_required": [
    "accessibility_regression_report",
    "ai_prompt_injection_test",
    "data_retention_impact_review"
  ],
  "owners": {
    "engineering": "eng_assessment",
    "security": "security_lead",
    "privacy": "privacy_lead",
    "accessibility": "accessibility_lead"
  }
}
```

```
}  
}
```

The dashboard blocks release when:

A P0/P1 release-blocking finding is open.
A required control has no current evidence.
A data-flow change lacks privacy approval.
An AI/provider/model/tool change lacks evaluation approval.
A critical accessibility regression is unresolved.
A high-risk exception is expired or unapproved.
A grade/integration write workflow lacks reconciliation evidence.

Product backlog priorities

Priority	Capability	Why it matters
P0	Shared identity/RBAC, tenant isolation, audit logs, secrets, encryption, backup restore	Core HECVAT and TrustEd security foundation
P0	Data inventory, retention/deletion/legal hold, consent/share/revoke	Privacy rubric, FERPA readiness, student data agency
P0	Accessibility design system, testing gate, issue workflow, ACR/VPAT evidence	Procurement requirement and differentiated student experience
P0	AI inventory, provider review, policy engine, no-training default, evaluations	Gen-AI rubric and institutional trust
P1	Evidence vault, compliance control mapping, HECVAT response library	Faster security/procurement cycle
P1	LTI/OneRoster/QTI test harness and integration health	Interoperability proof and supportability
P1	Incident/BCP runbooks, tabletop, status communications	Operational reliability
P1	Grade ledger, grade-release audit, source-aware feedback	High-stakes academic data integrity
P2	Customer Trust Evidence dashboard	Differentiates procurement and renewal experience
P2	Public transparency/changelog and Semester Standard scorecard	Brand and market leadership
P3	Automated policy drafting/AI evidence summarization	Efficiency after controls and human review exist

Implementation sequence

1. Define control IDs and a canonical control taxonomy.
2. Import the current HECVAT and 1EdTech rubric requirements into the mapping service, preserving source/version references.
3. Create controls, owners, evidence requirements, and release gates.
4. Integrate CI/CD, cloud, IAM, accessibility, AI gateway, and ticketing signals.
5. Populate the evidence vault with current artifacts and expiry/review dates.

6. Run an internal assessment and produce findings/remediation records.
7. Use the results to create engineering sprint work and customer-specific HECVAT responses.
8. Enable a restricted customer-facing trust view only after access controls and evidence review are proven.

The competitive advantage is not a dashboard with green checks. It is a system that lets Semester answer, quickly and truthfully: **what control exists, who owns it, how do we know it works, what evidence proves it, and what happens if it fails?**

**

1. <https://www.imsglobal.org/spec/security-rubric/v1>
2. <https://www.1edtech.org/1edtech-article/new-1edtech-rubrics-provide-valuable-insights-for-educators-selecting-trusted>
3. <https://www.1edtech.org/standards/accessibility-rubric>
4. <https://www.1edtech.org/workstream/vetting>
5. <https://www.1edtech.org/standards/data-privacy>
6. <https://www.1edtech.org/standards/ai-rubric>
7. <https://site.imsglobal.org/certifications>
8. <https://www.1edtech.org/1edtech-trusted-apps-alliance>
9. <https://www.1edtech.org/article/1edtech-consortium-launches-trusted-apps-program-institutions-and-edtech-suppliers>
10. <https://cdck-file-uploads-global.s3.dualstack.us-west-2.amazonaws.com/sketchup/original/3X/3/e/3e9528da628640c3ab004333b9ec2759cbebbba99.pdf>
11. <https://eye-in.com/interactive-wayfinding/hecvat-security>
12. https://cdn.prod.website-files.com/65f2558d9f3ac6c64f1b8bb1/67052c47b4c213ea0c5bd746_completed_HECVATLite306_8_10_24.pdf
13. <https://www.1edtech.org/program/trustedapps>
14. <https://www.1edtech.org/standards/security-practices-rubric>
15. <https://www.1edtech.org/standards/data-privacy/rubric>